

Security Operations Centre Breach and Attack Simulation



Security Operations & Incident response

- What is Breach & Attack Simulation (BAS)?
- Features of BAS
 1. Endpoint Security
 2. Email and Web Gateway Assessment
 3. Web Application Firewall
 4. Lateral Movement
 5. Immediate Threats
- Risk Score
- Network Placement
- 3 Approaches of Implementation



Labs

- Using RanSIM for simulating ransomware
- Use Infection Monkey from Akamai for testing security
- Students to use Defender in Windows for testing the security

Security Operations Centre (SOC)

- A Security Operations Centre (SOC) is a centralized function (**team + processes + technology**) responsible for continuously **monitoring, detecting, analyzing, and responding to cybersecurity threats** across an organization's infrastructure—networks, servers, endpoints, cloud, and applications.
- Core objectives
 - **Threat detection** – Identify suspicious or malicious activity from logs, alerts, and telemetry.
 - **Incident response** – Investigate, contain, eradicate, and recover from security incidents.
 - **Continuous monitoring** – Maintain visibility into infrastructure health and security posture.
 - **Risk reduction** – Reduce dwell time, prevent lateral movement, and protect critical assets.
 - **Compliance support** – Provide audit trails, reporting, and regulatory alignment.



Key functions inside a SOC

- **Security Monitoring**

- Log collection (Windows Event Logs, Syslog, firewall, EDR, WAF, proxy)
- Alert triage and prioritization
- Behavioral analysis

- **Detection Engineering**

- Create detection rules/use-cases
- Map threats to frameworks like MITRE ATT&CK
- Reduce false positives

- **Incident Response**

- Triage → Investigation → Containment → Eradication → Recovery
- Host/network forensics
- Malware analysis coordination

- **Threat Intelligence**

- Consume IOC feeds (IPs, domains, hashes)
- Track adversary TTPs
- Proactive threat hunting

- **Vulnerability & Posture Visibility**

- Exposure monitoring
- Security baseline drift detection

SOC Roles:

- **L1 Analyst (Monitoring/Triage)** – Handles alerts, validates incidents.
- **L2 Analyst (Investigation)** – Deep analysis, correlation, scoping.
- **L3 Analyst / IR Specialist** – Advanced response, forensics, containment.
- **Threat Hunter** – Proactive search for undetected threats.
- **Detection Engineer** – Builds rules and analytics.
- **SOC Manager** – Strategy, metrics, maturity.



Breach & Attack Simulation (BAS)

- **Breach & Attack Simulation (BAS)** is a cybersecurity practice and technology that continuously and safely emulates real-world cyberattacks against an organization's environment to evaluate the effectiveness of its security controls, detection capabilities, and incident response readiness.
- The primary objective of BAS is to answer three critical security questions:
 1. **Can an attacker get in?**
 2. **If they do, will we detect it?**
 3. **Can we stop or contain the attack in time?**



How BAS Works?

1. Threat Emulation

- Simulates attacker techniques such as:
 - Phishing
 - Credential dumping
 - Lateral movement
 - Command-and-Control (C2) callbacks
 - Data exfiltration
- Techniques are mapped to MITRE ATT&CK.

2. Safe Execution

- Uses non-destructive payloads.
- No real malware or data loss.
- Runs in production or production-like environments.

3. Security Control Testing

- Evaluates:
 - Firewalls
 - EDR/XDR
 - SIEM
 - Email security gateways
 - WAF
 - Identity and access controls

4. Detection & Response Validation

- Confirms whether alerts are generated.
- Measures response time and accuracy.
- Identifies gaps and misconfigurations.

Key Attack Techniques Simulated in BAS

▪ **Initial Access**

- Phishing email delivery
- Malicious links and attachments
- Exploit of exposed services

▪ **Execution & Persistence**

- PowerShell-based execution
- Registry-based persistence
- Scheduled tasks

▪ **Privilege Escalation**

- Token manipulation
- Exploiting misconfigured privileges

▪ **Lateral Movement**

- Pass-the-Hash / Pass-the-Ticket
- SMB and RDP movement

▪ **Command and Control**

- DNS tunnelling
- HTTPS beaconing

▪ **Exfiltration**

- Data staging
- Encrypted outbound traffic simulation

BAS Tools

- AttackIQ
- SafeBreach
- Cymulate
- Picus Security
- XM Cyber (attack path-focused)

Features of BAS – Endpoint Security

- BAS validates the effectiveness of endpoint protection controls against real attacker techniques.
- **What is tested**
 - EDR/XDR detection and prevention
 - Antivirus and behavioral analysis engines
 - Host-based firewall and exploit protection
 - OS security configurations
- **Value**
 - Confirms whether endpoint threats are blocked, detected, or missed
 - Identifies misconfigured EDR policies
 - Improves endpoint visibility and alert quality
- **Attack techniques simulated**
 - Malicious PowerShell execution
 - Living-off-the-Land Binaries (LOLBins)
 - Credential dumping simulations
 - Persistence mechanisms (registry, scheduled tasks)
 - Ransomware behavior (safe simulation)



Features of BAS – Email and Web Gateway Assessment

- This feature tests the first line of defense, where most attacks originate.
- **Email security testing**
 - Phishing email delivery simulation
 - Malicious attachments (safe payloads)
 - Embedded malicious URLs
 - Spoofed sender and domain impersonation
- **Web gateway testing**
 - Access to malicious or newly registered domains
 - Command-and-Control (C2) traffic simulation
 - URL reputation and SSL inspection validation
- **Value**
 - Measures phishing prevention effectiveness
 - Validates sandboxing and URL filtering
 - Reduces successful initial access vectors

Features of BAS – Web Application Firewall (WAF)

- BAS evaluates the **protection of web applications** against common and advanced attacks.
- **Attack techniques simulated**
 - SQL Injection (SQLi)
 - Cross-Site Scripting (XSS)
 - Command Injection
 - Directory Traversal
 - OWASP Top 10 attack patterns
- **What is validated**
 - WAF rule coverage
 - False positives vs false negatives
 - Signature and behavioral detection accuracy
- **Value**
 - Confirms real-world WAF effectiveness
 - Improves rule tuning
 - Reduces application-layer attack exposure



Features of BAS – Lateral Movement

- This feature tests the ability of attackers to **move within the internal network after initial compromise.**
- **Techniques simulated**
 - Pass-the-Hash / Pass-the-Ticket
 - SMB and RDP movement
 - Abuse of administrative shares
 - Active Directory enumeration
 - Privilege escalation paths
- **Controls tested**
 - Network segmentation
 - Identity access controls
 - East-West traffic monitoring
 - EDR and NDR visibility
- **Value**
 - Identifies weak segmentation and trust relationships
 - Validates Zero Trust assumptions
 - Prevents domain-wide compromise



Features of BAS – Immediate Threats

- BAS continuously validates defenses against active and emerging threats.

- **Threat coverage**

- Ransomware attack chains
- Zero-day-like behavior simulations
- Known APT group TTPs
- Threat-intelligence-driven scenarios

- **What is measured**

- Speed of detection
- Alert accuracy
- Response readiness
- Containment capability

- **Value**

- Reduces dwell time
- Ensures readiness against current threat landscape
- Supports rapid defensive adjustments

Risk Score in BAS

- A **Risk Score** in Breach & Attack Simulation represents a **quantified measure of an organization's exposure to cyberattacks**, calculated based on how successfully simulated attacks bypass existing security controls.
- It converts technical BAS results into a **business-readable risk indicator** for security teams, management, and auditors.
- The BAS risk score is designed to answer:
 - ✓ How exposed are we **right now**?
 - ✓ Which security gaps create the **highest business risk**?
 - ✓ Are our security controls **improving or degrading over time**?



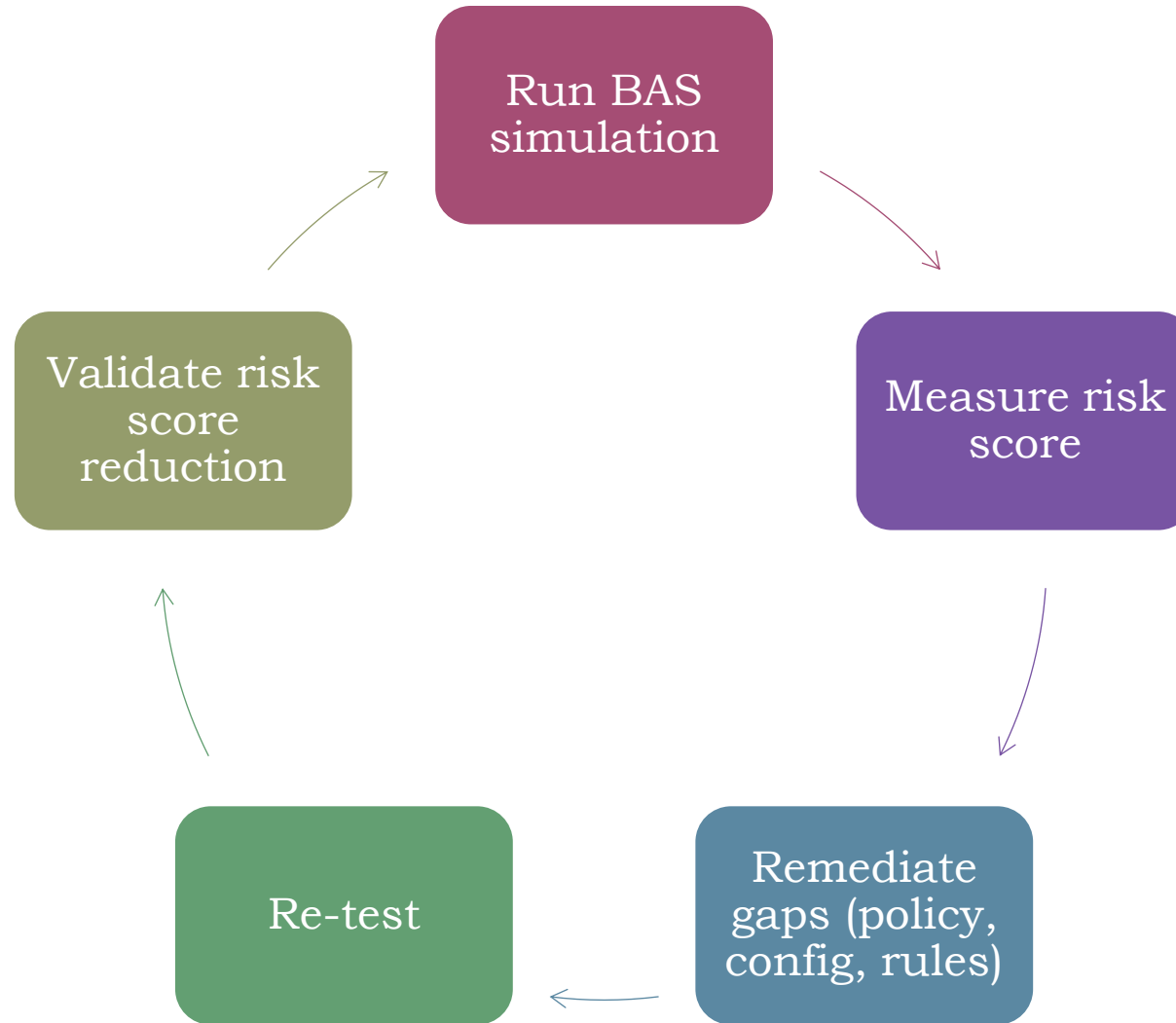
Risk Score Representation

Risk scores are usually presented as:

- Numeric scale (e.g., 0–100)
- Risk levels:
 - Low
 - Medium
 - High
 - Critical
- Visual indicators:
 - Heat maps
 - Trend graphs
 - Attack path diagrams

Risk Score	Meaning
0–20	Strong security posture
21–40	Minor gaps, manageable risk
41–60	Moderate risk, needs remediation
61–80	High risk, likely breach path
81–100	Critical risk, immediate action required

Continuous Risk Reduction Cycle



Network Placement

- Network Placement in BAS refers to **where and how BAS components** (agents, sensors, or appliances) are deployed within the enterprise network to accurately simulate attacker behavior and validate security controls across different network zones.
- Correct placement is critical; improper placement leads to incomplete attack paths, false confidence, or missed control gaps.
- Network placement ensures BAS can:
 - Simulate attacks from external, internal, and lateral positions
 - Test defense-in-depth controls
 - Accurately validate network, endpoint, identity, and cloud security



Common BAS Deployment Components

- Attack Simulation Engine / Controller
- Internal Agents (Lightweight)
- External Attack Nodes
- Cloud-based simulators (optional)



BAS Network Placement Models

- **External Network Placement (Outside the Perimeter)**

- Internet-facing simulation nodes
- Cloud-based BAS infrastructure
- Attack Scenarios
 - Phishing
 - Web application attacks
 - Exploitation of exposed services

- **Internal Network Placement (User Zone)**

- User VLANs
- Corporate LAN
- Attack Scenarios
 - Credential theft
 - Internal reconnaissance
 - Command-and-control callbacks

BAS Network Placement Models

■ **Server / Data Centre Placement**

- Application servers
- Database servers
- Active Directory domain controllers
(agentless preferred)
- Attack Scenarios
 - Lateral movement
 - Privilege escalation
 - Domain compromise paths

■ **Cloud Network Placement**

- AWS / Azure / GCP workloads
- SaaS environments
- Attack Scenarios
 - Cloud privilege escalation
 - Misconfiguration abuse
 - Cross-account access

BAS Network Placement Models

■ **DMZ Placement**

- DMZ networks hosting public-facing services
 - Attack Scenarios
 - Web server compromise
 - Pivoting attempts to internal network



3 Approaches of Implementation

- Three Approaches of Implementing Breach & Attack Simulation (BAS)
- Breach & Attack Simulation can be implemented using three primary approaches, depending on organizational maturity, risk appetite, and operational objectives.
- Each approach aligns with how security teams validate controls and improve resilience.
 1. Automated Continuous BAS (Platform-Driven)
 2. Scenario-Based / Threat-Focused BAS
 3. Incremental / Control-Focused BAS



Automated Continuous BAS (Platform-Driven)

- A fully automated BAS platform continuously runs predefined and custom attack simulations across the environment with minimal human intervention.
- **Key Characteristics**
 - Scheduled and on-demand simulations
 - MITRE ATT&CK-mapped attack techniques
 - Continuous control validation
 - Centralized dashboards and risk scoring



Automated Continuous BAS (Platform-Driven)

- **Best Suited For**

- Mature SOCs
- Large enterprises
- Environments with complex security stacks

- **Advantages**

- Real-time visibility into security posture
- Rapid identification of control gaps
- Trend analysis and measurable improvement

- **Limitations**

- Licensing and operational cost
- Requires initial tuning and integration

Scenario-Based / Threat-Focused BAS

- BAS is executed using specific attack scenarios, often based on current threats, ransomware campaigns, or known APT groups.
- **Key Characteristics**
 - Threat-intelligence-driven simulations
 - Focus on high-risk attack paths
 - Targeted and contextual testing
- **Best Suited For**
 - Organizations responding to emerging threats
 - Industries with targeted attack risk
 - Purple team exercises



Scenario-Based / Threat-Focused BAS

- **Advantages**

- High relevance to real-world attacks
- Better prioritization of remediation
- Improves detection for known adversaries

- **Limitations**

- Not continuous
- Limited coverage outside selected scenarios

Incremental / Control-Focused BAS

- BAS is implemented gradually, focusing on specific security controls or domains (endpoint, email, network, identity) one at a time.
- **Key Characteristics**
 - Phased rollout
 - Domain-specific testing
 - Controlled scope and impact
- **Best Suited For**
 - Organizations new to BAS
 - Smaller teams or limited budgets
 - Compliance-driven environments



Incremental / Control-Focused BAS

- **Advantages**

- Lower complexity and risk
- Easier operational adoption
- Clear improvement milestones

- **Limitations**

- Slower coverage expansion
- Limited visibility into full attack chains initially





That's all Folks!